

Executive GRC Assessment Report

Trainory fitness and wellness technology platform

Report field	Detail
Prepared for	Executive Leadership
Prepared by	Jared Sanchez
Assessment date	September 2026
Framework	NIST Cybersecurity Framework 2.0
Classification	Case Study

Executive recommendation
Continue controlled operation while remediating High residual risks. Approve the VitaSync integration only under defined conditions, remove inappropriate access immediately, and require evidence that critical controls are operating before accepting residual risk.

Purpose

Provide a decision-focused view of Trainory’s cyber risk posture, control maturity, assurance gaps, and remediation priorities.

Case study notice: Trainory, VitaSync, and all assessment data are fictional.

1. Executive Summary

Trainory's baseline security posture is developing. Existing controls reduce aggregate modeled risk by approximately 28%, but 11 of 15 identified risks remain High after considering those controls. Several documented controls still require approval, implementation, testing, and retained operating evidence.

Residual exposure	CSF maturity	Access exceptions	Open findings
11 High risks	50% / 22 outcomes	11 of 28 records	14 access + vendor

Management decision

Treat the current posture as elevated but manageable. Maintain service with defined guardrails, prioritize the highest-impact corrective actions, and require owners to provide closure evidence.

Primary conclusions

- Identity and access weaknesses create immediate exposure, including a terminated contractor account, unnecessary production and database access, and an unowned privileged service account.
- Application, cloud, monitoring, and recovery controls require formal baselines, recurring testing, and evidence of consistent operation.
- VitaSync's 70% weighted control score supports conditional approval because six material vendor findings remain.
- The selected NIST CSF baseline is 50%. Policies and plans count as designed controls, not proof of operating effectiveness.

Immediate management actions

1. Disable and investigate the terminated contractor account. Preserve offboarding and activity-review evidence.
2. Remove direct production and database access that is not required. Replace broad roles with least-privilege alternatives.
3. Place VitaSync under conditional approval with monthly remediation reporting, owners, due dates, closure evidence, and defined risk-acceptance authority.

2. Scope and Methodology

The assessment covers a fictional cloud-based fitness and wellness platform that stores customer profiles, workout history, performance information, account data, and wearable-device data. The review focuses on confidentiality, integrity, availability, privacy, and customer trust.

Assessment scope

- 15 business, technology, data, security, and third-party assets.
- 15 cybersecurity and privacy risk scenarios using a 5 × 5 likelihood-impact method.
- 22 selected NIST CSF 2.0 outcomes across all six functions.
- 25 vendor-control questions for VitaSync, a fictional wearable-data integration provider.
- 28 workforce, contractor, vendor, and service-account access records.

Method

Stage	Activity	Output
1	Establish scope	Assets, owners, sensitive data, dependencies, and business impact
2	Assess risk	Inherent and residual scores, controls, treatment, and ownership
3	Evaluate controls	NIST CSF status, evidence, gaps, priority, and owner
4	Review assurance	Vendor and access exceptions converted into findings
5	Prioritize action	Owners, target dates, required evidence, and rationale
6	Report decisions	Metrics, dashboards, roadmap, and management disposition

Scoring model

Risk score = Likelihood (1–5) × Impact (1–5). Scores of 1–4 are Low, 5–9 Moderate, 10–16 High, and 17–25 Critical. Residual risk is the exposure remaining after current controls. Ratings support, but do not replace, risk-owner and leadership judgment.

Limitation: Policy creation shows control design. Implementation requires approval, testing, operating records, and recurring review.

3. Enterprise Risk Posture

No risks remain Critical after current controls, but exposure is concentrated in the High category. Existing safeguards are not yet strong or mature enough to reduce most material scenarios to Moderate or Low.

Highest-priority enterprise risks

ID	Scenario	Residual	Priority treatment
TRN-R001	Account compromise	15 / High	Customer MFA, credential screening, rate limiting, and stronger alerting
TRN-R006	Unpatched application vulnerability	15 / High	Automated scanning and severity-based remediation deadlines
TRN-R003	Excessive privileged access	12 / High	Least-privilege roles, approvals, quarterly reviews, and monitoring
TRN-R011	Backup restoration failure	12 / High	Recovery objectives, isolated backups, and quarterly restoration tests
TRN-R012	Insufficient security monitoring	12 / High	Centralized logs, alert ownership, and escalation testing
TRN-R013	Inadequate privacy and consent	12 / High	Data inventory, consent evidence, retention, and deletion workflow

Risk treatment position

Mitigation is the dominant treatment. Transfer applies selectively to third-party services. Monitoring is appropriate only when ownership, thresholds, contingency measures, and escalation are documented. Operational teams should not accept High risk without defined authority and a recorded rationale.

Modeled effect of planned treatment

Measure	Baseline	After planned treatment
Aggregate modeled score	Inherent risk baseline	Approximately 28% lower residual exposure
High residual risks	11 of 15	Reassess after evidence confirms control operation
Critical residual risks	0	Maintain monitoring and escalation thresholds

4. Control Maturity and NIST CSF Alignment

The assessment reviewed 22 selected NIST CSF 2.0 outcomes. Three are Implemented, 16 are Partial, and three are Not Implemented, producing a weighted maturity score of 50%.

Function	Outcomes	Maturity	Management focus
Govern	5	40%	Risk appetite, responsibility, policy governance, and vendor requirements
Identify	7	71%	Recurring validation of asset, threat, vulnerability, and risk records
Protect	7	43%	Access lifecycle, secure configuration, patching, data protection, and awareness
Detect	1	50%	Centralized monitoring, alert ownership, and escalation
Respond	1	0%	Approve and exercise the incident-response process
Recover	1	50%	Recovery objectives, restoration tests, and communications

Design versus operating effectiveness

The Access Control Policy and Incident Response Plan strengthen documented control design. A control should be rated Implemented only after approval, communication, assigned ownership, consistent execution, testing, and retained evidence.

Evidence required

- Policy approvals, employee acknowledgments, role assignments, and exception records.
- Completed access certifications and verified remediation tickets.
- Vulnerability, patch, configuration, logging, and alert-review reports tied to service levels.
- Incident exercises, lessons learned, backup restoration results, and recovery performance.
- Vendor assurance reports, contract clauses, subprocessor records, and finding closure evidence.

5. Assurance Results

Quarterly access review

The review examined 28 access records. Seventeen were retained, three required modification, five removal, and three escalation. Eleven exceptions produced eight formal findings: four Critical and four High.

Response	Finding	Required evidence
Terminate	Former contractor retained AWS access	Disable access, revoke sessions, review activity, and preserve evidence
Restrict	Developer and support roles exceeded job needs	Remove direct database access and broad administrator roles
Govern	Privileged service account lacked an owner	Assign ownership, rotate credentials, document scope and review date
Time-limit	Vendor repository access lacked expiration	Record sponsor, scope, expiration, and quarterly validation
Correct mover	Marketing employee retained support access	Remove inherited access and review the transfer process

VitaSync third-party assessment

VitaSync received a weighted control score of approximately 70%. The recommendation is Conditional Approval because six material findings remain: three Critical and three High.

Condition	Rating	Required action
Independent assurance	High	Obtain current SOC 2 Type II or equivalent assurance
Incident notification	Critical	Require notice within 24 hours of confirmed Trainory impact
Disaster recovery	Critical	Review current disaster-recovery test results before production approval
Retention and deletion	Critical	Define retention, backup deletion, timing, and written confirmation
Privileged access	High	Require quarterly privileged-access review evidence
Subprocessor obligations	High	Confirm notification, audit-cooperation, security, and termination rights

Approval boundary: Limit integration scope, use separate credentials, restrict API permissions, enforce contract conditions, and track remediation. Conditional approval is not a claim that the vendor is compliant or risk-free.

6. Remediation Roadmap

The roadmap addresses immediate exposure before broader program maturity work. Accountable owners should validate dates, dependencies, resources, and acceptance authority.

Timing	Objective	Actions	Accountability
0–30 days	Contain exposure	Disable terminated access, remove excess privileges, assign the service-account owner, and retain closure evidence	Cybersecurity, IT, system owners
0–30 days	Set governance	Approve risk appetite, acceptance authority, control ownership, and monthly remediation review	Executive leadership, Compliance
31–60 days	Strengthen vendor conditions	Resolve notification, disaster recovery, retention, assurance, and subprocessor requirements	Vendor Management, Privacy/Legal
31–60 days	Improve protection	Implement configuration baselines, scanning, patch SLAs, least privilege, and account safeguards	Cloud, Development, Cybersecurity
61–90 days	Validate response and recovery	Conduct an incident tabletop and restoration test; record lessons and corrective actions	Incident team, Cloud, Communications
61–90 days	Measure effectiveness	Collect recurring evidence, retest findings, update residual risk, and report trends	GRC, control owners, Internal Audit

Governance cadence

Cadence	Review	Participants
Monthly	High-risk remediation and overdue findings	Risk owners and executive sponsor
Quarterly	Risk register, access, vulnerability, and recovery metrics	GRC and control owners
Annually	Policies, vendor assessment, CSF maturity, and incident exercise	Executive leadership and GRC
Event-driven	Material incidents, architecture changes, new data use, or vendor changes	Relevant owner with GRC review

Success measures

- Reduce High residual risks after evidence-based reassessment.
- Close Critical access and vendor findings or obtain authorized risk acceptance.
- Increase maturity through verified implementation, not documentation alone.
- Complete access reviews, incident exercises, and restoration tests on schedule.

7. Management Conclusion

Trainory has established an asset inventory, risk register, control assessment, governance documents, vendor due diligence, access certification, analytics dashboard, and automated risk reporting. Together, these deliverables connect assets to risks, controls, evidence, findings, remediation, and management decisions.

The current assessment does not support declaring the environment mature or fully compliant. Risk is elevated but manageable through immediate access correction, vendor conditions, stronger technical controls, tested response and recovery, and recurring evidence-based oversight.

Recommended disposition

Approve continued controlled operation and limited conditional vendor integration, subject to the 90-day roadmap, monthly executive review, closure validation, and formal acceptance of residual risk above tolerance.

Assessment evidence

Deliverable	Evidence demonstrated
Company Profile and Scope	Business context, system boundary, stakeholders, and assumptions
Asset Inventory	Assets, ownership, sensitivity, criticality, and dependencies
Cybersecurity Risk Register	Inherent and residual scoring, treatment, ownership, and actions
NIST CSF 2.0 Assessment	Control status, evidence, gaps, priorities, and framework mapping
Access Control Policy	Identity lifecycle, least privilege, reviews, and exceptions
Incident Response Plan	Roles, severity, lifecycle, communications, and exercises
Vendor Risk Assessment	VitaSync due diligence, findings, and conditional decision
Quarterly Access Review	Certification decisions, evidence log, and corrective actions
GRC Analytics Dashboard	Formula-driven KPIs, charts, and normalized source data
Python Risk Scoring Tool	Validation, scoring, prioritization, reporting, and tests

Framework reference: National Institute of Standards and Technology, Cybersecurity Framework 2.0 — <https://www.nist.gov/cyberframework>

Case study notice: Trainory, VitaSync, all people, systems, ratings, evidence, findings, dates, and decisions are fictional. This report is not an audit opinion, certification, legal conclusion, or production authorization.